

MANUEL DE SÉCURITÉ ET D'EXPLOITATION

ONGarde — Maintien en Condition de Sécurité (MCS) et Plan de Sauvegarde

Introduction : Philosophie de Sécurité

Ce document détaille les mécanismes de défense et la stratégie de résilience mis en place sur l'infrastructure centralisée **ONGarde**. L'objectif est de fournir une documentation claire sur la façon dont le système se protège contre les menaces internes et externes, et comment il garantit la pérennité des données associatives en cas d'incident majeur.

1. Verrouillage de l'Architecture (Hardening)

La sécurité de l'infrastructure ne repose pas sur un seul outil, mais sur une approche de **Défense en Profondeur** (Defense in Depth).

1.1 Le Principe du Moindre Privilège (Blocage du droit CREATE)

L'application Web (Nextcloud) communique avec la base de données via l'utilisateur `ongarde_user`. Par conception, cet utilisateur a été volontairement amputé de ses droits structurels.

- **Ce qu'il peut faire (Statut de "Locataire")** : Lire, ajouter, modifier ou supprimer des données utilisateurs dans les tableaux qui existent déjà.
- **Ce qu'il ne peut pas faire (Statut d'"Architecte")** : Le droit de création (`CREATE`) et de destruction de structure (`DROP`) lui a été retiré (`REVOKE CREATE ON SCHEMA public`).



Pourquoi ce blocage est-il vital ? (Le scénario de l'attaque)

Si un attaquant découvre et exploite une faille de type **Injection SQL** depuis l'interface Web (Nextcloud), il parvient à exécuter des commandes dans la base de données avec les mêmes droits que l'application.

- **Si le droit CREATE était actif** : Le pirate aurait le champ libre pour créer des tables cachées afin d'y stocker des malwares, générer des "tables fantômes" géantes pour saturer l'espace disque du serveur (DDoS), ou modifier l'architecture globale pour s'octroyer des accès détournés.
- **Grâce au blocage (REVOKE)** : L'attaquant est enfermé dans la structure existante. S'il tente de construire des éléments malveillants, la base de données bloque l'action et renvoie une erreur `permission denied`. Le périmètre de l'attaque potentielle est ainsi drastiquement réduit.

1.2 Chiffrement de Bout en Bout

Aucune donnée ne transite en clair sur le réseau local, empêchant toute écoute réseau (Sniffing/Man-in-the-Middle) :

- **Flux Client ↔ Serveur Web** : Le serveur Apache force la redirection de tout le trafic HTTP vers HTTPS (port 443) et utilise l'en-tête **HSTS** pour interdire aux navigateurs de rétrograder la connexion.
- **Flux Serveur Web ↔ Base de Données** : Le moteur PostgreSQL exige une connexion cryptée en utilisant la directive `hostssl` dans son fichier d'authentification `pg_hba.conf`. Une tentative de connexion en clair est immédiatement rejetée.

2. Stratégie de Résilience : Le Plan de Sauvegarde

Pour garantir la disponibilité des données, des routines de sauvegardes locales automatisées et chiffrées ont été déployées sur les deux nœuds de production.

Évolution de l'Architecture (Vision 3-2-1)

L'architecture actuelle garantit des sauvegardes fiables avec une rétention de 7 jours. Dans une phase ultérieure d'évolution du Système d'Information (SI), ces archives locales ont vocation à être poussées de nuit vers une **DMZ**, puis externalisées vers un Cloud souverain et éthique (ex: **Infomaniak Swiss Backup**), afin de valider à 100 % la norme de sauvegarde de type 3-2-1.

2.1 Sauvegarde de la Base de Données (ongarde-DB)

L'export de la base de données est géré par un script bash s'exécutant avec les droits du compte système `postgres`, garantissant l'absence totale de mot de passe écrit en clair dans le code.

Emplacement du script : `/root/backup_db_locale.sh`

```
#!/bin/bash
# Sauvegarde locale de la base de données ONGarde
DATE=$(date +%Y%m%d_%H%M)
DESTINATION="/sauvegardes/db_locale"
FICHER="$DESTINATION/ongarde_db_$DATE.sql.gz"

# Export et compression à la volée par l'utilisateur système postgres
sudo -u postgres pg_dump ongarde_db | gzip > $FICHER

# Rétention stricte : Suppression des archives de plus de 7 jours
find $DESTINATION -name "ongarde_db_*.sql.gz" -type f -mtime +7 -delete
```

2.2 Sauvegarde des Configurations (ongarde-Nextcloud)

Les fichiers critiques permettant le fonctionnement de Nextcloud sont compressés et versionnés quotidiennement.

Emplacement du script : `/root/backup_web_locale.sh`

```
#!/bin/bash
# Sauvegarde locale des fichiers de configuration Nextcloud
DATE=$(date +%Y%m%d_%H%M)
DESTINATION="/sauvegardes/web_locale"
ARCHIVE="$DESTINATION/nextcloud_config_$DATE.tar.gz"

# Compression du répertoire de configuration
tar -czf $ARCHIVE /var/www/nextcloud/config/

# Rétention stricte : Suppression des archives de plus de 7 jours
find $DESTINATION -name "nextcloud_config_*.tar.gz" -type f -mtime +7 -delete
```

3. Automatisation et Étanchéité des Droits (Cron)

L'exécution des scripts est confiée au planificateur de tâches du système (`cron`).

- **02h00** : Lancement de la sauvegarde de la base de données.
- **02h30** : Lancement de la sauvegarde du serveur Web.

✓ Sécurité par Isolation (Sandboxing)

Ces tâches automatisées ont été inscrites dans la table `crontab` de l'utilisateur **root**. Par conséquent, même en cas de compromission totale du service Web (utilisateur `www-data`), l'attaquant ne disposera pas des privilèges nécessaires pour lire, modifier ou supprimer les scripts de sauvegarde ou les archives générées. Le système de sauvegarde reste sain et isolé.